Lección 13 - Recuperación frente a desastres: del evento al plan ejecutable

Cuando ocurra, ¿cómo sigue funcionando la organización y vuelve a la normalidad sin improvisar?

Material de estudio autocontenido | Basado en NIST SP 800-34 Rev. 1, CSF 2.0, SP 800-61r3 y SP 800-184.

Gemini Notebook

De proteger a resistir: El cambio de paradigma



Existir no es poder recuperar.

Tener un respaldo guardado no demuestra que se pueda restaurar a tiempo ni de forma íntegra.



La prioridad la define el impacto.

No todo vuelve a la vez. Primero se recupera lo que más le duele perder al negocio.



Las dependencias mandan.

Un servicio crítico solo se recupera si la infraestructura técnica que necesita ya está disponible.



Sin validación no hay retorno.

Volver a producción exige probar exhaustivamente, no suponer que todo funciona.

Gemini Notebook

Contingencia como marco general: Planes vs. Insumos

	Planes de Acción	
1	Respuesta a incidentes (IR)	¿Qué está pasando y cómo lo contengo?
2	Continuidad del negocio (BC)	¿Cómo sigo operando lo esencial mientras tanto?
3	Recuperación ante desastres (DR)	¿Cómo restauro la tecnología que soporta esos procesos?
	Insumo: Respaldo	¿De dónde saco los datos?

Es un insumo, no un plan.



Gemini Notebook

Por qué un respaldo NO garantiza la recuperación



Hay copia de respaldo.

(Es solo una promesa)



Restauramos en 3 h, probado.

(Es un hecho)

1. **Tiempo:** Cuánto tarda realmente la restauración completa.
2. **Integridad:** Que los datos no estén corruptos o incompletos.
3. **Cobertura:** Que incluya configura-aciones críticas, no solo archivos.
4. **Funcionamiento:** Que el sistema restaurado opere e integre correctamente.

Gemini Notebook

Objetivos de Tiempo como idea: MTPD, RTO y RPO



Gemini Notebook

Escenarios de desastre y la Política de Continuidad



Energía/Instalaciones
Corte eléctrico, incendio, inundación.



Datos/Sistemas
Ransomware, borrado, corrupción.



Personal
Enfermedad masiva, renuncia clave.



Proveedores
Caída de cloud, corte de un servicio crítico.

La Política de Continuidad

Fija el marco de acción.
Debe definir:

- Alcance.
- Roles.
- Autoridad (quién puede declarar el desastre).
- Compromiso ineludible de probar los planes.

Gemini Notebook

Estrategia: 5 Frentes y Sitios Alternos

Personas **Instalaciones** **Tecnología** **Datos** **Proveedores**

La estrategia debe cubrir los cinco frentes.



Gemini Notebook

Prioridad del Negocio: MTPD y Modo Manual

Proceso	MTPD (Horas)	¿Admite modo manual?
Proceso A	4	Sí, parcial
Proceso B	8	No
Proceso C	72	Sí

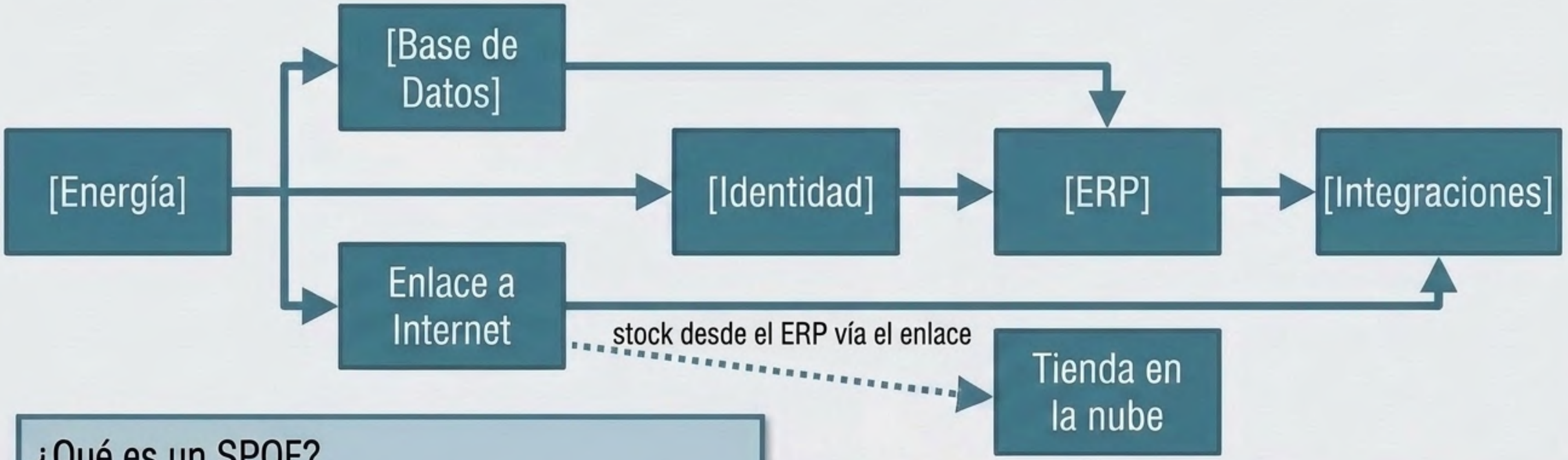
Reglas de Interpretación:

- A menor MTPD, mayor urgencia de recuperación técnica.
- Si no admite modo manual, depende por completo de la recuperación técnica.
- Si admite modo manual, la continuidad lo sostiene mientras tanto.

Gemini Notebook

Dependencias y Puntos Únicos de Falla (SPOF)

→ Las flechas se leen: es necesario para



¿Qué es un SPOF?

Un recurso sin alternativa del que dependen muchos otros. Si cae, arrastra a los recursos y procesos que dependen de él.
Cómo reconocerlo: muchos recursos dependen de él y no tiene alternativa.

El plan DEBE decir qué hacer si el SPOF cae, o cómo eliminarlo desde el diseño.

Gemini Notebook

Prioridad del Negocio frente a Orden Técnico

Prioridad del Negocio
(Lo que más duele perder)



Orden Técnico
(Lo que se necesita primero)



“El servicio responde” (la tienda en la nube está activa) no es lo mismo que “puede cumplir lo que vende” (requiere stock actualizado y despacho).

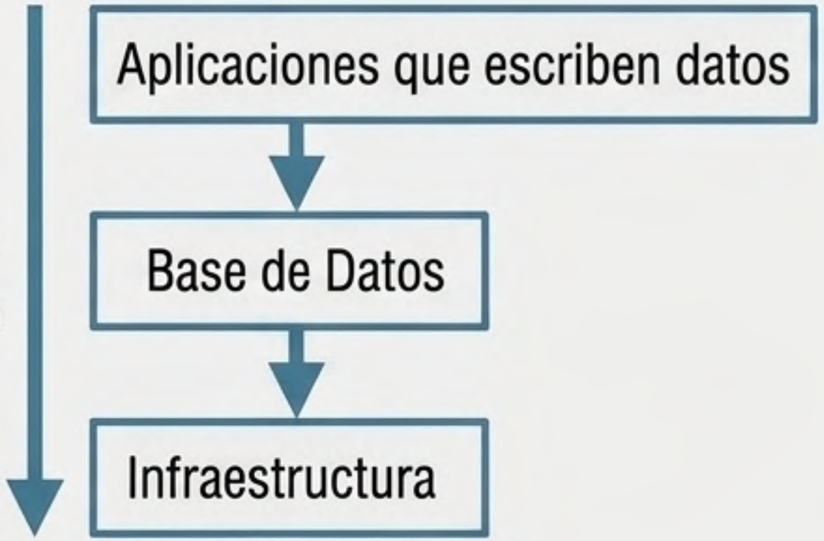
Gemini Notebook

Los Primeros Minutos y la Declaración del Desastre



Decidir antes de que se agote.

Apagado Ordenado



Declarar el Desastre

- ☑ - **Quién**: Rol designado (con suplente explícito).
- ☑ - **Criterios**: Duración estimada, procesos críticos caídos, MTPD en riesgo, seguridad de personas.
- ☑ - **Plazo**: Tomar la decisión antes de agotar autonomía.
- ☑ - **Comunicación** (Interna y **Externa**): Incluir obligatoriamente la prioridad que NO se puede garantizar.

Gemini Notebook

Secuencia de Recuperación con Validación

Paso	Responsable (ejemplo)	Cómo se valida antes de avanzar
1. Estabilizar: proteger a las personas y hacer el apagado ordenado.	Comité de Crisis, IT, Seguridad Física	Confirmación de seguridad de personas, estado de UPS/generadores, log de apagado.
2. Activar la continuidad solo donde hay alternativa e informar qué queda detenido.	Dueños de Procesos, Coordinador de continuidad	Checklist de activación de procedimientos manuales, comunicado emitido.
3. Recuperar energía, red e identidad.	Infraestructura IT, Redes, Seguridad	Pruebas de encendido, conectividad de red, los usuarios pueden autenticarse
4. Comprobar la integridad de los datos: si están íntegros, arranque normal; si no, restaurar desde una copia verificada.	Equipo de Datos, Administrador de Backup	Verificación de integridad (checksums, logs), validación de punto de restauración, prueba de restauración.
5. Levantar las aplicaciones según la prioridad.	Equipo de Aplicaciones, DBA	Pruebas básicas de que las aplicaciones críticas responden
6. Validar y reconciliar lo registrado en modo degradado.	Usuarios Clave, Dueños de Procesos	Cotejo de registros manuales vs. sistema, aprobación de conciliación.
7. Decidir el retorno con aprobación del dueño del proceso; si una validación falla, revertir.	Comité de Crisis, Dueños de Procesos	Acta de aprobación formal del retorno, plan de reversión listo.

Gemini Notebook

Las 3 fases de NIST SP 800-34 y el Retorno

Activación y Notificación

Definir el objetivo y el alcance del plan (qué procesos y sistemas cubre).

Recuperación

Reconstitución

Condiciones para el retorno:

- ☑ Pruebas técnicas y funcionales.
- ☑ Datos conciliados.
- ☑ Aprobación formal del dueño del proceso.
- ☑ Registro de lo perdido y lo pendiente.



Después de una interrupción se deben programar pruebas pendientes, en especial una restauración completa con tiempo medido.

Gemini Notebook

Caso Práctico PUERTO CENTRAL: Ransomware vs. Corte Eléctrico

Las fases del plan son las mismas, las decisiones cambian.

Corte Eléctrico	Ransomware (cifra ERP y archivos)
Estabilizar: apagado ordenado antes de que la UPS se agote.	IR aísla, preserva evidencia y define el alcance.
Continuidad con toma de pedidos en modo manual.	Continuidad con toma de pedidos en modo manual.
Comprobar la integridad de los datos: si están íntegros, arranque normal sin restaurar.	Restaurar solo lo afectado desde una copia anterior a la infección verificada por hash.
Retorno Retorno con pruebas técnicas y funcionales (factura y despacho de prueba), reconciliación del inventario y aprobación del dueño.	**Retorno** Retorno con pruebas técnicas y funcionales (factura y despacho de prueba), reconciliación del inventario y aprobación del dueño.

Orden de recuperación de PUERTO CENTRAL: 1. Identidad y red, 2. Base de datos y ERP, 3. Integración logística, 4. Tienda (reconectar el stock).

Gemini Notebook

Errores frecuentes y relación con CSF 2.0

Un plan defendible **NO** comete estos errores:

- Confundir tener un respaldo con tener un plan.
- Recuperar aplicaciones antes que sus dependencias técnicas.
- Confundir la prioridad del negocio con el orden técnico.
- Restaurar datos sin comprobar primero su integridad.
- Decidir el apagado cuando la UPS ya se agotó.
- Volver a producción sin la aprobación del dueño del proceso.
- No identificar los SPOF.
- No definir quién tiene autoridad para declarar el desastre.
- Tener un plan que nunca se probó.

Función CSF 2.0	Relación/Acción
Govern	política y autoridad
Identify	procesos y dependencias
Protect	respaldos y redundancia
Detect	aviso del evento
Respond	contención
Recover	restaura y comunica el restablecimiento

Gemini Notebook